

CyberRisikoCheck – Ergebnisreport

DIN SPEC 27076 · Kristian Dabic · Cyber Security & GRC

Erstellt am: 08.09.2026

Gesamtrisiko: NIEDRIG (18 / 100)

Solide Basis – mit gezieltem Optimierungspotenzial

Ihre Grundschutzmaßnahmen greifen. Einzelne der 27 Anforderungen der DIN SPEC 27076 sind jedoch noch nicht vollständig umgesetzt.

9 von 27 Anforderungen der DIN SPEC 27076 sind nicht vollständig erfüllt – davon 2 mit kritischer Gewichtung.

Auswertung je Themenfeld

Organisation & Sensibilisierung	0/6 erfüllt · Risiko 50%
Identitäts- & Berechtigungsmanagement	3/5 erfüllt · Risiko 33%
Datensicherung & Protokollierung	5/5 erfüllt · Risiko 0%
Patch- & Änderungsmanagement	4/4 erfüllt · Risiko 0%
Schutz vor Schadprogrammen	2/3 erfüllt · Risiko 14%
IT-Systeme & Netzwerke	4/4 erfüllt · Risiko 0%

Alle 27 Anforderungen im Detail

Organisation & Sensibilisierung

ORG.1 · Antwort: Teilweise

Gibt es in Ihrem Unternehmen eine schriftlich benannte Person, die für IT-Sicherheit verantwortlich ist?

Empfehlung: Benennen Sie eine verantwortliche Rolle für Informationssicherheit inkl. Aufgabenbeschreibung und Eskalationsweg.

ORG.2 · Antwort: Teilweise

Existieren verbindliche Regelungen bzw. Richtlinien zur IT-Nutzung, die allen Mitarbeitenden bekannt sind?

Empfehlung: Erstellen Sie eine kurze, verständliche IT-Nutzungsrichtlinie und lassen Sie deren Kenntnisnahme dokumentieren.

ORG.3 · Antwort: Teilweise

Werden Ihre Mitarbeitenden regelmäßig zu Cybergefahren wie Phishing und Social Engineering sensibilisiert?

Empfehlung: Führen Sie mindestens jährliche Awareness-Schulungen inkl. Phishing-Simulationen durch.

ORG.4 · Antwort: Teilweise

Sind die für den Geschäftsbetrieb kritischen IT-Systeme, Anwendungen und Daten dokumentiert?

Empfehlung: Erstellen Sie ein Inventar Ihrer IT-Assets und bewerten Sie deren Kritikalität für den Geschäftsbetrieb.

ORG.5 · Antwort: Teilweise

Sind IT-Dienstleister und Cloud-Anbieter vertraglich zu Sicherheitsanforderungen verpflichtet?

Empfehlung: Vereinbaren Sie Sicherheitsanforderungen, Meldepflichten und Reaktionszeiten schriftlich mit allen Dienstleistern.

ORG.6 · Antwort: Teilweise · kritisch

Existiert ein dokumentierter Notfallplan für IT-Sicherheitsvorfälle (z. B. Ransomware)?

Empfehlung: Erstellen Sie einen Notfallplan mit Meldekettten, Verantwortlichkeiten und Wiederanlaufplan – und üben Sie ihn.

Identitäts- & Berechtigungsmanagement

IDM.1 · Antwort: Teilweise

Verfügt jede Person über ein eigenes, persönliches Benutzerkonto?

Empfehlung: Schaffen Sie Sammelkonten ab und richten Sie personalisierte Benutzerkonten mit Nachvollziehbarkeit ein.

IDM.2 · Antwort: Nein · kritisch

Werden administrative Tätigkeiten über separate Administrator-Konten durchgeführt?

Empfehlung: Trennen Sie Administrations- und Arbeitskonten strikt und beschränken Sie Adminrechte auf das Notwendige.

IDM.3 · Antwort: Ja · kritisch

Ist für alle externen Zugänge (E-Mail, VPN, Cloud) eine Mehr-Faktor-Authentifizierung aktiv?

IDM.4 · Antwort: Ja

Gibt es Vorgaben für sichere Passwörter und werden diese technisch erzwungen?

IDM.5 · Antwort: Ja

Werden Berechtigungen bei Rollenwechsel oder Austritt zeitnah angepasst bzw. entzogen?

Datensicherung & Protokollierung

DAT.1 · Antwort: Ja · kritisch

Werden alle geschäftskritischen Daten regelmäßig und automatisiert gesichert?

DAT.2 · Antwort: Ja · kritisch

Wird mindestens eine Sicherungskopie offline oder unveränderbar (immutable) aufbewahrt?

DAT.3 · Antwort: Ja · kritisch

Wird die Wiederherstellung der Backups mindestens jährlich getestet und dokumentiert?

DAT.4 · Antwort: Ja

Sind sensible Daten auf Notebooks, Servern und mobilen Datenträgern verschlüsselt?

DAT.5 · Antwort: Ja

Werden sicherheitsrelevante Ereignisse protokolliert und regelmäßig ausgewertet?

Patch- & Änderungsmanagement

PAT.1 · Antwort: Ja · kritisch

Werden Betriebssysteme und Anwendungen zeitnah und nachweisbar mit Sicherheitsupdates versorgt?

PAT.2 · Antwort: Ja · kritisch

Ist sichergestellt, dass keine Systeme ohne Herstellersupport (End-of-Life) im Einsatz sind?

PAT.3 · Antwort: Ja

Werden Änderungen an IT-Systemen vor der Umsetzung geprüft und dokumentiert?

PAT.4 · Antwort: Ja

Werden Schwachstellen Ihrer IT (z. B. per Scan oder Herstellermeldungen) systematisch verfolgt?

Schutz vor Schadprogrammen

MAL.1 · Antwort: Ja · kritisch

Ist auf allen Endgeräten und Servern ein aktueller Schadsoftware-Schutz aktiv?

MAL.2 · Antwort: Teilweise

Werden E-Mails und Webzugriffe technisch auf Schadcode und Phishing gefiltert?

Empfehlung: Setzen Sie E-Mail- und Webfilter mit Anhangs-/Linkprüfung sowie SPF, DKIM und DMARC ein.

MAL.3 · Antwort: Ja

Ist die Installation von Software durch Benutzende eingeschränkt bzw. reglementiert?

IT-Systeme & Netzwerke

NET.1 · Antwort: Ja · kritisch

Ist Ihr Netzwerk durch eine konfigurierte und überwachte Firewall vom Internet getrennt?

NET.2 · Antwort: Ja

Sind Gast-, Produktions- bzw. unsichere Geräte vom internen Netz getrennt (Segmentierung)?

NET.3 · Antwort: Ja · kritisch

Erfolgt der Fernzugriff (Homeoffice, Wartung) ausschließlich über gesicherte Verbindungen?

NET.4 · Antwort: Ja

Sind mobile Geräte (Notebooks, Smartphones) zentral verwaltet und bei Verlust sperrbar?

Fördermittel & nächste Schritte

Für die Umsetzung der Maßnahmen stehen staatliche Förderprogramme mit bis zu 50 % Zuschuss zur Verfügung (z. B. go-digital oder regionale Digitalisierungsprämien). Gerne prüfen wir Ihre Fördermöglichkeiten und begleiten die Umsetzung – von Quick Wins bis zum zertifizierungsfähigen ISMS nach ISO 27001.

Kontakt: kontakt@kristian-dabic.de